

## Third-Party and Supplier Security Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-008

Version 1.0 | Effective: 20 Feb 2026

### Document Control Page

| Field                             | Details                                                           |
|-----------------------------------|-------------------------------------------------------------------|
| Policy Title                      | Third-Party and Supplier Security Policy                          |
| Policy Number                     | FTAID-POL-008                                                     |
| Author                            | Head of Procurement and Vendor Management                         |
| Policy Owner                      | Chief Information Security Officer                                |
| Reviewer                          | Information Security Manager                                      |
| Approver                          | Chief Operating Officer                                           |
| Version                           | 1.0                                                               |
| Effective Date                    | 20 February 2026                                                  |
| Current Review Date               | 20 February 2026                                                  |
| Next Review Date                  | 20 February 2027                                                  |
| ISO 27002:2022 Primary Domain     | Organisational Controls                                           |
| ISO 27002:2022 Primary Sub-domain | Supplier relationships                                            |
| ISO 27002:2022 Primary Control    | 5.19 – Information security in supplier relationships             |
| Related Policies                  | Data Protection Policy, Cloud Security, Privileged Account Policy |

## 1. Purpose and Scope

### Purpose:

To manage security risks from third parties accessing FortisAid systems, cloud platforms, or PHI during EHR integration, RPM device supply, and analytics services.

### Scope:

All suppliers, vendors, contractors providing cloud services, RPM devices, EHR integrations, lab systems, or analytics platforms.

### FortisAid Context:

Secures cloud vendors (AWS/Azure), RPM device manufacturers, EHR integrators handling sensitive patient data.

## 2. ISO 27002:2022 Multi-Domain Alignment

| ISO Domain                      | ISO Sub-domain         | Control     | Policy Coverage                    |
|---------------------------------|------------------------|-------------|------------------------------------|
| <b>Organisational (Primary)</b> | Supplier relationships | <b>5.19</b> | Vendor risk assessment/onboarding  |
| <b>Organisational</b>           | Supplier agreements    | <b>5.20</b> | Contractual security clauses/BAA's |
| <b>Organisational</b>           | Cloud services         | <b>5.23</b> | Cloud vendor requirements          |
| <b>Organisational</b>           | Monitoring suppliers   | <b>5.22</b> | Ongoing vendor performance         |
| <b>Technological</b>            | Endpoint devices       | <b>8.1</b>  | Vendor device access standards     |

## 3. Policy Statements / Requirements

### 3.1 Vendor Risk Assessment and Classification (5.19)

- Classify vendors: **High Risk** (PHI access: EHR, RPM, labs), **Medium** (cloud infra), **Low** (non-data).
- Pre-contract assessment** mandatory: ISO 27001/SOC2 certification, security questionnaire, penetration test review.
- High-risk vendors require **annual on-site/remote audit** by Information Security Manager.

### 3.2 Contractual Security Requirements (5.20)

- All contracts include **Business Associate Agreements (BAAs)** with: 24hr breach notification, right to audit, £5M liability minimum.

- **Cloud vendors (5.23):** UK/EEA data residency, customer-managed encryption keys, SOC2 Type II.
- **RPM device vendors:** Secure boot, firmware signing, vulnerability disclosure process.

### 3.3 Access and Technical Controls

- Vendor access via **just-in-time privileged accounts** (8.2), MFA mandatory, session recording.
- Vendor endpoints comply with **8.1** (encryption, EDR, patching); no direct PHI export.
- **API integrations** use OAuth2/JWT with scoped tokens, rate limiting.

### 3.4 Monitoring and Performance Management (5.22)

- **Vendor security scorecards** updated monthly: patch compliance, incident history, cert validity.
- **Quarterly business reviews** for high-risk vendors covering security KPIs.
- **60-day advance notice** required for vendor changes (M&A, subcontractors, data center moves).

## 4. Roles and Responsibilities

| Role                                    | Responsibilities                         |
|-----------------------------------------|------------------------------------------|
| Chief Operating Officer                 | Approves high-risk vendor contracts      |
| Chief Information Security Officer      | Policy owner, vendor risk oversight      |
| Head of Procurement (Author)            | Vendor assessments, contract negotiation |
| Information Security Manager (Reviewer) | Technical audits, scorecard monitoring   |
| Data Protection Officer                 | BAA review, PHI compliance               |
| IAM Specialist                          | Vendor account provisioning              |

## 5. Compliance and Enforcement

### Monitoring Activities:

| Activity              | Frequency    | Responsible     | Evidence       |
|-----------------------|--------------|-----------------|----------------|
| New vendor assessment | Pre-contract | Procurement     | Risk reports   |
| Scorecard update      | Monthly      | InfoSec Manager | Vendor portal  |
| High-risk audit       | Annual       | InfoSec Manager | Audit findings |
| Contract review       | Biennial     | Procurement     | BAA register   |

**Non-Compliance:** High-risk vendor violations trigger 30-day remediation or termination.

## 6. Training and Awareness

- **Mandatory completion** of Third-Party Security policy-specific training within **30 days** of joining.
- **Annual refresher training** for all staff interacting with vendors (procurement, IT, clinical teams).
- **Role-specific training** for privileged roles and clinical staff:
  - Vendor risk classification and reporting
  - Secure vendor access procedures (JIT accounts, session recording)
  - Incident escalation for vendor security events
  - Contractual security clause verification

**Training Delivery:** Delivered via Wizer platform; vendor-facing version provided to high-risk suppliers.

## 7. Review and Revision

- This policy will be reviewed **annually** or following **significant incidents** (vendor breaches, supply chain attacks, regulatory changes).
- **Next scheduled review: 23 February 2027.**
- **Triggers for unscheduled review:** Major vendor incidents, new GDPR processor requirements, cloud security framework updates.